

Security incident report

Section 1: Identify the network protocol involved in the incident

The network protocols identified in the packet captures during the investigation are DNS (Domain Name System) and HTTP (Hypertext Transfer Protocol).

DNS was utilized to resolve the domain names (yummyrecipesforme.com and greatrecipesforme.com) into their corresponding IP addresses.

HTTP was utilized by the browser to request the webpage content, establish the connection with the compromised server, and initiate the download of the malicious executable file.

Section 2: Document the incident

Following multiple customer reports to the helpdesk regarding suspicious file download prompts and subsequent computer performance degradation, an investigation was launched into the yummyrecipesforme.com web server. The website owner also reported being locked out of the administrative panel.

To safely investigate, the cybersecurity team utilized a sandbox environment and the network protocol analyzer tcpdump. Accessing the URL immediately prompted the download of an executable file disguised as a browser update. Upon execution, the file redirected the browser to a malicious domain (greatrecipesforme.com).

A senior analyst reviewed the server's source code and confirmed the system was compromised. Unauthorized JavaScript had been injected to trigger the download prompt and execute the redirection script. The root cause was determined to be a successful brute-force attack against the website's administrative panel. The attacker exploited a default administrative password to gain unauthorized access, embedded the malicious code, and subsequently changed the password to lock out the legitimate owner. It was noted that the

authentication portal lacked any controls to prevent brute-force attempts.

Section 3: Recommend one remediation for brute force attacks

To prevent future brute-force attacks, the organization should implement an account lockout policy (limiting the number of login attempts).

This security measure is highly effective because it directly disrupts the methodology of a brute-force attack. By configuring the system to automatically lock the administrative account for a specific duration after a small number of consecutive failed login attempts (e.g., 3 to 5 attempts), attackers are prevented from using automated scripts to rapidly guess thousands of passwords. This forces a delay that makes brute-force guessing computationally impractical. Furthermore, it is critical that all default administrative credentials are changed to strong, unique passwords immediately upon system deployment.